

Vulnerability Assessment Report

Target: http://demo.testfire.net

Overall Security Score: 49.29/100

Passive Reconnaissance

Web Server: Apache-Coyote/1.1

Language: Java/JSP

Vulnerabilities Identified

Script Context XSS (High)

CVSS Score: 7.2 | CWE: CWE-79 | OWASP: A03:2021-Injection

Description: Data is reflected directly inside a <script> block, allowing immediate code execution.

Missing Security Header (Medium) - Content-Security-Policy

CVSS Score: 6.0 | CWE: CWE-116 | OWASP: A05:2021-Security Misconfiguration

Description: Missing CSP exposes to XSS.

Missing Security Header (Medium) - X-Frame-Options

CVSS Score: 5.1 | CWE: CWE-1021 | OWASP: A05:2021-Security Misconfiguration

Description: Missing X-Frame-Options exposes to clickjacking.

HTTP Method Misconfiguration (Medium)

CVSS Score: 5.0 | CWE: CWE-749 | OWASP: A05:2021-Security Misconfiguration

Description: Dangerous HTTP methods (like TRACE, PUT, or DELETE) are enabled when they are not required.

Missing Security Header (Medium) - X-Content-Type-Options

CVSS Score: 4.4 | CWE: CWE-693 | OWASP: A05:2021-Security Misconfiguration

Description: Missing X-Content-Type-Options security header.

Missing Security Header (Medium) - Referrer-Policy

CVSS Score: 4.4 | CWE: CWE-693 | OWASP: A05:2021-Security Misconfiguration

Description: Missing Referrer-Policy security header.

Server Banner Disclosure (Low)

CVSS Score: 3.4 | CWE: CWE-200 | OWASP: A05:2021-Security Misconfiguration

Description: The server exposes exact version information, aiding attackers in identifying known exploits.